

## Plantilla de Reporte Ejecutivo (Presentación tipo PowerPoint)

Esta plantilla describe una posible estructura de presentación para compartir con la alta dirección los resultados de la encuesta sobre KEV, vulnerabilidades, pentesting, SIEM y capacitación.

Cada sección corresponde, en la práctica, a una o varias diapositivas.

### Portada

- Título sugerido: «Diagnóstico de Madurez en Gestión de Vulnerabilidades, KEV y Resiliencia Digital».
- Subtítulo: «Resultados de la encuesta organizativa».
- Datos: nombre de la organización, fecha, área responsable.

### 1. Resumen ejecutivo

**Objetivo de la sección:** ofrecer en 1–2 diapositivas los mensajes clave para quienes no verán el resto del informe.

Elementos recomendados:

- 3–5 mensajes principales, por ejemplo:
- Nivel global de madurez (IGM) y su posición en la escala (Inicial, Básico, Definido, Gestionado, Optimizado).
- 2–3 fortalezas destacadas (por ejemplo, buen programa de formación, uso de SIEM con casos de uso avanzados).
- 2–3 áreas de mejora críticas (por ejemplo, ausencia de SLAs para KEV, baja frecuencia de pentests, métricas limitadas).
- Un gráfico sencillo (barra o velocímetro) con el IGM global.

### 2. Contexto y objetivos de la evaluación

Contenido sugerido:

- Breve explicación del contexto:
- Importancia de KEV y vulnerabilidades explotadas.
- Entorno regulatorio (ENS, NIS2, ISO, etc.).
- Objetivos específicos de la encuesta:
- Medir madurez.
- Priorizar inversiones.
- Disponer de una línea base para seguimiento.
- Alcance:
- Unidades/entidades incluidas.
- Periodo de recogida de datos.

### 3. Metodología y enfoque

Contenido sugerido:

- Descripción del cuestionario:
- Nº de preguntas, bloques temáticos.
- Perfiles que respondieron.
- Breve explicación del cálculo del IGM:
- Subíndices por dimensión.
- Ponderaciones aplicadas.
- Notas sobre interpretación:
- Autodiagnóstico.
- Complementar con otras evidencias.

Gráfico recomendado:

- Esquema visual del modelo (bloques: Gobierno, Vulnerabilidades, Pentesting, SIEM, Capacitación, Métricas/ROI).

### 4. Resultados globales de madurez

#### Diapositiva 4.1 – Índice Global de Madurez (IGM)

- Gráfico principal: barra o velocímetro con el valor del IGM en escala 0–100.
- Texto: nivel cualitativo asociado (por ejemplo, «Nivel 3 – Definido»).

#### Diapositiva 4.2 – Subíndices por dimensión

- Gráfico tipo radar (spider) o barras comparando:
- IGM\_GOV
- IGM\_VUL
- IGM\_PEN
- IGM\_SIEM
- IGM\_AWR
- IGM\_MET

Comentarios breves destacando:

- Dimensiones más fuertes.
- Dimensiones más débiles.

IGM\_MET

Comentarios breves destacando:

## 5. Gobierno y estrategia de vulnerabilidades (GOV)

Contenido sugerido:

- Diapositiva con indicadores clave, por ejemplo:
- % de organizaciones con política formal de gestión de vulnerabilidades que menciona KEV.
- % con roles claramente definidos para la gestión de KEV.
- Frecuencia típica de revisión del catálogo KEV.
- Comentarios:
- Grado de integración de KEV en la gestión de riesgos.
- Madurez percibida frente a marcos de referencia.

Gráficos posibles:

- Barras apiladas con distribución de respuestas a GOV-01, GOV-02, GOV-04.

## 6. Gestión operativa de vulnerabilidades y KEV (VUL)

Contenido sugerido:

- Indicadores destacados:
- Nivel de inventario de activos y cobertura de escaneos.
- Existencia de procesos automáticos para correlacionar KEV con activos.
- Medición (o no) de tiempos de remediación.
- Trato específico a dispositivos perimetrales y sistemas legacy.
- Mensajes clave:
- Grado de control sobre la «superficie de ataque conocida».
- Riesgos asociados a KEV abiertas y sistemas antiguos.

Gráficos posibles:

- Gráfico de barras mostrando la distribución de niveles de madurez en VUL.
- Un breve caso ilustrativo (sin datos sensibles) de «situación típica» identificada.

## 7. Pruebas de penetración y ejercicios (PEN)

Contenido sugerido:

- Frecuencia de pentests.
- Cobertura de KEV en el alcance de pruebas.
- Uso de ejercicios de Red/Purple Team.
- Proceso de gestión de hallazgos.

Gráficos posibles:

- Barras de frecuencia (por ejemplo, % que realiza pentests al menos anuales).

Comentario narrativo:

- Riesgo de «pentesting cosmético» vs. pruebas alineadas con amenazas reales.

## 8. Monitorización, SIEM y detección (SIEM)

Contenido sugerido:

- Situación de SIEM/SOC (24x7, parcial, inexistente).
- Presencia de casos de uso específicos para explotación de vulnerabilidades.
- Integración de inteligencia de amenazas.
- Capacidad avanzada de detección basada en comportamiento.

Gráficos posibles:

- Gráfico de barras o tarta mostrando la distribución de situaciones SIEM-01.
- Indicadores de adopción de detección avanzada.

Mensajes clave:

- Capacidad real de ver y reaccionar cuando una KEV es explotada.

## 9. Capacitación, cultura y métricas (AWR, MET)

Contenido sugerido:

- Existencia y cobertura de programas de formación.
- Formación específica para roles técnicos.
- Métricas de capacitación (test, simulaciones, etc.).
- Uso de indicadores relacionados con KEV y vulnerabilidades.

Gráficos posibles:

- Barras de % de organizaciones con programa anual estructurado.
- Radar específico para cultura de reporte y formación.

Mensaje clave:

- El factor humano como amortiguador (o amplificador) del riesgo técnico.

## 10. ROI y priorización de iniciativas

Contenido sugerido:

- Breve explicación del enfoque de ROI utilizado.
- 3–5 iniciativas clave identificadas (por ejemplo, «Automatizar cruce KEV–inventario», «Reforzar SOC 24x7», «Programa técnico avanzado»).
- Para cada iniciativa:
- Beneficios esperados (cualitativos y, si es posible, cuantitativos).
- Estimación de coste.
- Indicadores de retorno (por ejemplo, reducción de pérdida esperada).

Gráficos posibles:

- Tabla resumen con iniciativas ordenadas por relación impacto/coste.
- Gráfico de burbujas (impacto vs. esfuerzo, con el tamaño representando el ROI estimado).

## 11. Hoja de ruta (roadmap) de mejora

Contenido sugerido:

- Propuesta de roadmap en 3 horizontes:
- Corto plazo (0–12 meses): quick wins y acciones urgentes (por ejemplo, SLAs KEV, mejoras básicas de inventario).
- Medio plazo (1–2 años): consolidación de procesos, ampliación de SIEM, mejora de pentesting.
- Largo plazo (>2 años): optimización, automatización avanzada, integración plena con gestión de riesgos y negocio.

Gráfico posible:

- Diagrama de Gantt de alto nivel o roadmap por fases.

## 12. Conclusiones y próximos pasos

Contenido sugerido:

- 3–5 conclusiones clave.
- Recomendaciones prioritarias.
- Propuesta de próximos pasos concretos:
- Validación de resultados con equipos clave.
- Definición formal de un plan de acción.
- Repetición de la encuesta en X meses para medir evolución.

Cierre sugerido:

- Mensaje positivo y realista: reconocimiento de avances y de retos, invitación a ver la ciberseguridad como una capacidad estratégica en construcción continua.

Con esta plantilla, la presentación ejecutiva deja de ser un desfile de tablas ininteligibles y se convierte en una historia clara: dónde estamos, qué nos preocupa, qué podemos hacer y por qué merece la pena hacerlo ahora.